

DLP trong Big Data

Ngăn ngừa rò rỉ dữ liệu

Giảng viên hướng dẫn:
PGS.TS. Đặng Trần Khánh
TS. Phạm Thị Bạch Huệ
ThS. Lương Vĩ Minh

25C12011 - Nguyễn Bảo Trâm
25C11012 - Võ Công Minh
25C12016 - Trần Huy Vũ
25C12031 - Dương Tấn Huỳnh Phong
Date: 24/09/2026

Mục Lục



1. Bài toán bảo mật Big Data



2. Nền tảng về DLP



3. DLP trong hệ thống Big Data



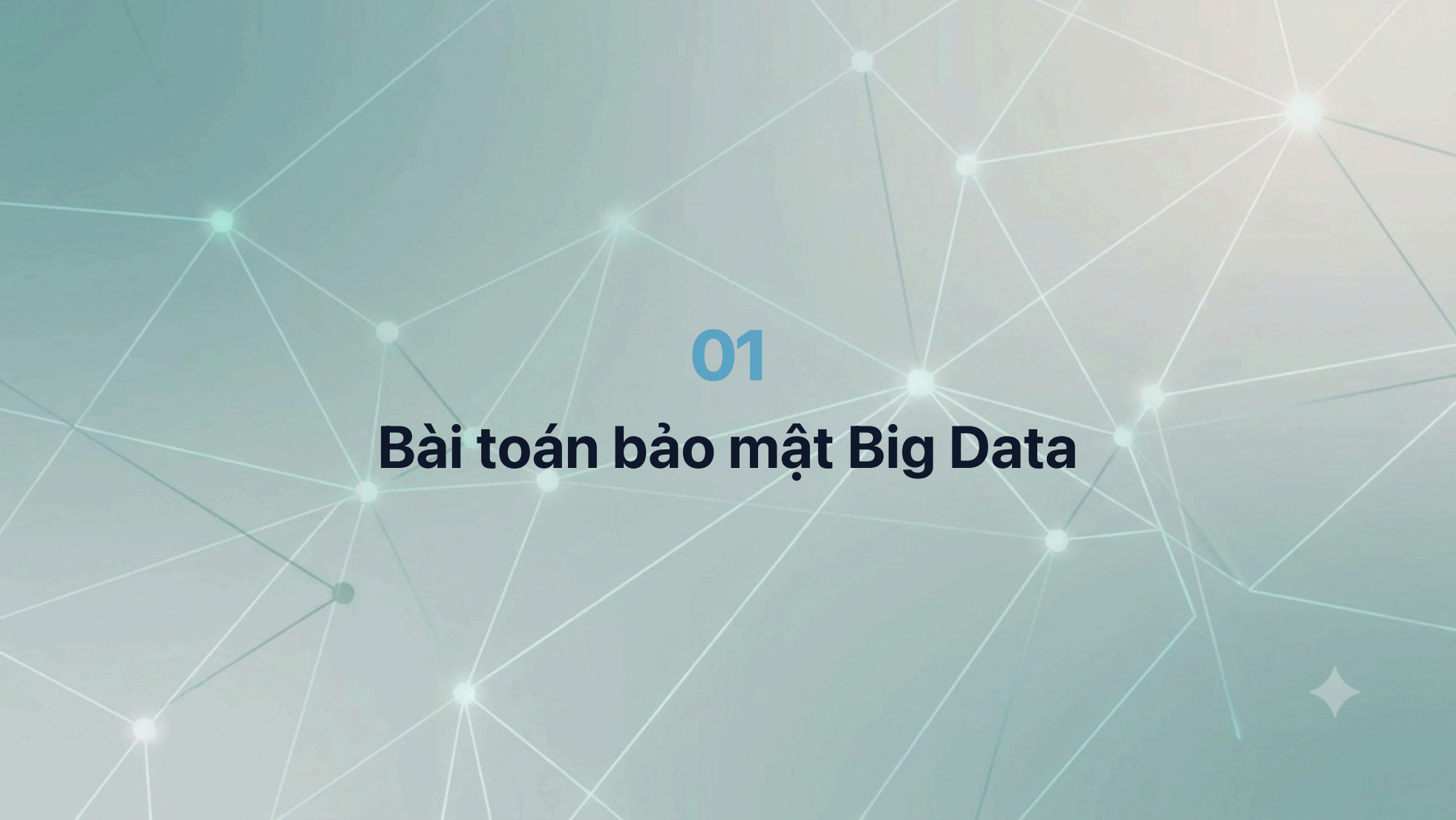
4. Giải pháp và xu hướng DLP



5. Demo và đánh giá



6. Giới hạn và kết luận



01

Bài toán bảo mật Big Data

Tổng quan và bài toán bảo mật Big Data

Tổng quan và bài toán bảo mật Big Data

VÒNG ĐỜI DỮ LIỆU TRONG BIG DATA



Quyền quá rộng

Tài khoản phân tích được đọc cả vùng dữ liệu không cần thiết.

Rò rỉ dữ liệu

Tệp nhảy cảm bị công khai hoặc xuất tới sai nơi.

Sửa đổi đầu vào

Bản ghi bị làm sai khiến mô hình cho kết quả lệch.

Gián đoạn dịch vụ

Cụm xử lý ngừng chạy, báo cáo không sẵn sàng.

Quy mô lớn · nhiều định dạng · xử lý phân tán · nhiều bản sao dẫn xuất → khó theo dõi dữ liệu sau mỗi bước.

Rò rỉ từ bản dữ liệu dẫn xuất

Rò rỉ từ bản dữ liệu dẫn xuất



Người thực hiện: chuyên viên phân tích có quyền đọc hợp lệ

Dữ liệu: hồ sơ khách hàng: mã khách hàng, email, lịch sử mua hàng

Bản sao mới: customer_segments do pipeline tạo, vẫn giữ mã và email

Vì sao quyền truy cập chưa đủ? Quyền đọc hợp lệ không xét đích gửi của bản xuất.

Điểm thử xuất cụ thể: gửi tập dữ liệu dẫn xuất tới đích bên ngoài chưa được phê duyệt

Hệ quả: xâm phạm quyền riêng tư, mất niềm tin, phát sinh điều tra và xử lý sự cố

Động cơ pháp lý: Luật Bảo vệ dữ liệu cá nhân số 91/2025/QH15, ban hành 26/06/2025, hiệu lực 01/01/2026. Luật không chỉ định một sản phẩm DLP cụ thể. Nguồn: Công văn bản Chính phủ.

Làm sao nhận diện dữ liệu nhạy cảm trong bản gốc hoặc bản dẫn xuất, rồi ngăn xuất tới đích chưa được duyệt?



02

Nền tảng về DLP

DLP là gì?

DLP là gì?

Data Leakage Prevention (DLP) dùng công cụ và policy để nhận diện dữ liệu nhạy cảm và kiểm soát việc chia sẻ hoặc xuất dữ liệu.

DLP là gì?

Data Leakage Prevention (DLP) dùng công cụ và policy để nhận diện dữ liệu nhạy cảm và kiểm soát việc chia sẻ hoặc xuất dữ liệu.

01

Vấn đề

Nhân viên được phép xem dữ liệu khách hàng. Nhưng họ muốn gửi file kết quả vẫn chứa email khách hàng đến một dịch vụ bên ngoài chưa được công ty cho phép.

02

DLP xử lý

DLP phát hiện email trong file, rồi kiểm tra nơi nhận theo policy của công ty.

03

Lợi ích

Ngăn email khách hàng bị gửi đến nơi chưa được phép. Hệ thống cũng ghi lại ai đã thử gửi và gửi đi đâu.

DLP trong Defense-in-Depth (DiD)

DLP trong Defense-in-Depth (DiD)



Các lớp bổ trợ nhau; sơ đồ không biểu thị thứ tự thực thi bắt buộc.



03

DLP trong hệ thống Big Data

DLP trên pipeline

DLP trên pipeline



① Dữ liệu đã lưu - phát hiện

Quét tệp / bảng trong data lake; gắn nhãn như **PII** (thông tin nhận dạng cá nhân).

② Bản dẫn xuất - xác minh lại

Quét đầu ra mới hoặc truyền nhãn theo lineage (quan hệ nguồn gốc); kiểm tra lại sau biến đổi.

③ Lúc xuất - quyết định và thực thi

Điểm xuất chặn trước khi ghi byte; kiểm tra nhãn + người / hành động + đích.

Vì sao Big Data khó hơn? Cùng tình huống `customer_segments` :

Khối lượng lớn

Quét nhiều bản ghi tốn thời gian.

Nhiều định dạng

CSV gốc, bảng và tệp xuất.

Bản dẫn xuất

`customer_segments` vẫn giữ ID, email.

Schema đổi

Cột mới có thể chưa được gắn nhãn.

Nhiều đường xuất

Mỗi đường cần điểm kiểm soát.

Ví dụ tích hợp: Atlas hỗ trợ metadata / lineage; Ranger hỗ trợ policy / audit trong dịch vụ tích hợp. Ứng dụng phải thực thi quyết định tại đường xuất của mình.

Ba cách tìm nội dung nhạy cảm

Ba cách tìm nội dung nhạy cảm

01 · QUY TẮC ĐỊNH DẠNG

Ví dụ: Phát hiện địa chỉ email theo mẫu ký tự.

Giới hạn: Dữ liệu biến dạng có thể bị bỏ sót; mẫu trùng có thể báo nhầm.

02 · FINGERPRINTING

Ví dụ: So khớp một đoạn với tài liệu nhạy cảm đã biết.

Giới hạn: Nội dung mới hoặc chỉnh sửa nhiều sẽ khó khớp.

03 · PHÂN LOẠI THEO NGỮ CẢNH (AI/ML)

Ví dụ: Nhận diện câu tiết lộ thông tin sức khỏe qua ngữ cảnh.

Giới hạn: Cần dữ liệu gán nhãn; mô hình có thể báo nhầm hoặc bỏ sót.

Kết quả phát hiện là đầu vào cho policy: dữ liệu + người thực hiện + hành động + đích → cho phép, cảnh báo hoặc chặn.



04

Giải pháp và xu hướng DLP

Giải pháp DLP hiện nay

Giải pháp DLP hiện nay

DBMS hỗ trợ, tùy sản phẩm: phân quyền, masking, audit. Với `customer_segments` trong data lake hoặc tệp xuất, DLP còn cần tìm nội dung → phân loại → quyết định chính sách → thực thi tại các đường xuất được kiểm soát.

Amazon Macie

DATA LAKE · AMAZON S3

Phát hiện / báo cáo: tự động khám phá hoặc chạy tác vụ để nhận diện dữ liệu nhạy cảm trong đối tượng S3 và ghi kết quả phát hiện.

Không phải: bộ chặn mọi lần xuất khỏi S3.

Microsoft Purview DLP

MỤC ĐƯỢC HỖ TRỢ TRONG FABRIC

Chính sách trên mục dữ liệu: như lakehouse và warehouse; có thể hiện gợi ý chính sách, gửi cảnh báo, và hạn chế truy cập theo cấu hình.

Phạm vi: chỉ loại mục được hỗ trợ; hạn chế truy cập đang ở bản xem trước; không mặc định chặn mọi luồng xuất.

Google Cloud Sensitive Data Protection

BIGQUERY · CLOUD STORAGE

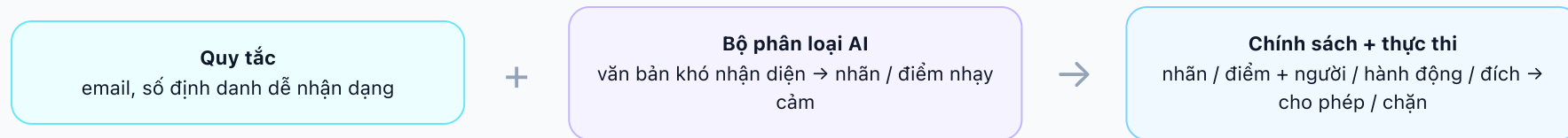
Khám phá / kiểm tra: lập hồ sơ và quét dữ liệu; có thể tạo bản đã loại định danh (de-identification).

Phân biệt: biến đổi dữ liệu khác với chặn hành động xuất.

Khả năng DBMS và sản phẩm DLP phụ thuộc dịch vụ, cấu hình và loại dữ liệu được hỗ trợ; không mặc định bao phủ mọi tệp dẫn xuất hay đường xuất.

AI hỗ trợ DLP

AI hỗ trợ DLP



De Renzis, Dosso & Testolin (2024)

Mô hình ngôn ngữ lớn (LLM) tạo văn bản tổng hợp để huấn luyện bộ phân loại có giám sát. Nghiên cứu tiếng Ý, sáu nhóm dữ liệu; xét phân loại văn bản và nhận diện thực thể có tên (NER).

Qawara & Alhindi (2026)

So sánh mô hình học máy và transformer cho văn bản nhạy cảm phụ thuộc ngữ cảnh; đánh giá hiệu quả lẫn hiệu suất tính toán.

Giới hạn: cần dữ liệu đại diện; khả năng chuyển miền / ngôn ngữ chưa chắc chắn; có dương tính giả, âm tính giả, lệch theo thời gian và chi phí tính toán. Kết quả tiếng Ý hoặc miễn nghiên cứu không thể mặc định áp dụng cho dữ liệu khách hàng tiếng Việt.

AI hỗ trợ phát hiện, không bảo đảm chặn xuất; ví dụ của seminar không triển khai AI.



05

Demo và đánh giá



Hai lần xuất, hai kết quả theo chính sách

Hai lần xuất, hai kết quả theo chính sách



TRƯỜNG HỢP A · ĐÍCH ĐÃ DUYỆT

customer_segments

customer_id · email · segment · spend
đích = kho phân tích nội bộ đã duyệt

NẾU có định danh VÀ đích chưa duyệt → CHẶN
NGƯỢC LẠI → CHO PHÉP + GHI

CHO PHÉP + GHI NHẬT KÝ

Lý do: cùng dữ liệu nhạy cảm; đích được duyệt.

TRƯỜNG HỢP B · ĐÍCH CHƯA DUYỆT

customer_segments

customer_id · email · segment · spend
đích = dịch vụ ngoài chưa duyệt

NẾU có định danh VÀ đích chưa duyệt → CHẶN

CHẶN + GHI NHẬT KÝ

Lý do: cùng dữ liệu nhạy cảm; chỉ đổi đích gửi.

Đây là minh họa logic chính sách, không phải demo chạy thật. Ví dụ dùng dữ liệu tổng hợp, không chứa thông tin cá nhân thật.

Kế hoạch đánh giá DLP

Kế hoạch đánh giá DLP

KẾ HOẠCH ĐÁNH GIÁ	
Phát hiện	phát hiện đúng · bỏ sót · báo động giả
Hiệu năng	thời gian quét theo kích thước dữ liệu · độ trễ quyết định
Thực thi	cho phép đúng báo cáo tổng hợp · chặn đúng bản nhay cảm
Độ bao phủ	thử mọi đường xuất và đường vòng có liên quan

Thử quyết định tại điểm xuất

Yêu cầu xuất → kiểm tra nhãn, người và đích → cho phép hoặc chặn trước khi ghi dữ liệu.

Giới hạn: đường truyền bỏ qua điểm xuất được giám sát sẽ không bị chặn bởi thiết kế này.

Chưa có số liệu thực nghiệm vì chưa có triển khai chạy được. Schwab et al. (2021) là nghiên cứu liên quan về độ trễ phân loại truy vấn theo chính sách, không phải benchmark cho thiết kế này.



06

Giới hạn và kết luận



Bảo vệ bản dữ liệu dẫn xuất

Bảo vệ bản dữ liệu dẫn xuất



Phát hiện trong bản dẫn xuất

Quét `customer_segments`, nhận diện các cột `customer_id` và `email`, rồi gắn nhãn nhảy cảm.

Chặn hành động xuất

Chặn lần gửi tập dữ liệu đó tới dịch vụ ngoài chưa được duyệt, tại đúng điểm xuất có kiểm soát.

có thể báo nhầm / bỏ sót

nhãn có thể lỗi thời sau biến đổi

đường xuất không giám sát vẫn là giới hạn

Phân loại bản dẫn xuất; thực thi chính sách tại từng đường xuất được kiểm soát.

References

Alneyadi et al. (2016)

A survey on data leakage prevention systems

Liu et al. (2015)

Privacy-Preserving Scanning of Big Content for Sensitive Data Exposure with MapReduce

Shapira et al. (2013)

Content-based data leakage detection using extended fingerprinting

Ahmed et al. (2021)

Automated detection of unstructured context-dependent sensitive information using deep learning

Schwab et al. (2021)

Performance Evaluation of Policy-Based SQL Query Classification for Data-Privacy Compliance

Herrera Montano et al. (2022)

Survey of Techniques on Data Leakage Protection and Methods to address the Insider threat

De Renzis et al. (2024)

Exploiting Large Language Models to Train Automatic Detectors of Sensitive Data

Qawara & Alhindi (2026)

Detecting Context-Dependent Sensitive Data in Unstructured Text



Thank You
for your attention!